

Aula 2 (Módulo 14) — Conduzindo uma Caça Guiada

Assim como a Aula 3 do Módulo 08, esta aula **não** entrega um exercício com resposta pronta — hunting de verdade não tem gabarito fixo, e treinar com um já resolvido não desenvolve a habilidade real. Aqui você aprende o **roteiro completo**, e pratica de verdade pedindo uma caça guiada ao vivo.

1. O roteiro de uma sessão de hunting

Passo 1 — Escolher e refinar a hipótese

Comece ampla, depois refine até ficar específica e testável (Aula 1, seção 2). Escreva a hipótese por escrito, antes de tocar em qualquer ferramenta — isso evita "vagar sem direção" pelos dados.

Passo 2 — Definir o escopo de dados

Que fontes de telemetria respondem a essa hipótese? (Sysmon? Logs de proxy? Netflow? EDR?) Que período de tempo faz sentido investigar? Hunting sem escopo definido vira uma busca infinita e improdutiva.

Passo 3 — Estabelecer o baseline (Aula 1)

Antes de procurar o anômalo, confirme o que é normal **nesse escopo específico** — não assuma, verifique.

Passo 4 — Rodar a query inicial

Traduza a hipótese em uma busca real. Se o resultado vier vazio, isso também é informação (a hipótese pode estar errada, ou os dados podem não cobrir o que você esperava — dois cenários diferentes que merecem conclusões diferentes).

Passo 5 — Pivotar sobre achados interessantes

Cada resultado interessante gera novas perguntas. Documente cada pivot e por que você o fez — isso constrói a trilha de raciocínio que outra pessoa (ou você mesmo, depois) poderá seguir.

Passo 6 — Montar a timeline

Organize tudo que encontrou em ordem cronológica — isso frequentemente revela relações de causa/efeito que não eram óbvias olhando os dados soltos.

Passo 7 — Concluir e documentar

Três desfechos possíveis:

- **Confirma achado real** → vira caso de investigação (conecta com o Módulo 08) e, se apropriado, incidente (Módulo 15).
- **Não confirma nada, mas melhora o baseline** → você aprendeu algo sobre o ambiente, mesmo sem achar uma ameaça — isso tem valor, documente mesmo assim.

- **Revela uma lacuna de detecção** → mesmo sem achar um ataque ativo, você percebeu que "se isso acontecesse, ninguém saberia" — vira input direto para o Módulo 21 (Detection Engineering): criar uma regra nova.

2. Como pedir uma caça guiada de verdade

Quando quiser praticar, me peça algo como: "*vamos fazer uma sessão de Threat Hunting*". Vou te dar um **ambiente fictício descrito em detalhe** (tipo de rede, sistemas presentes, volume aproximado de dados) e uma **hipótese de partida** — a partir daí, você conduz o roteiro dos 7 passos acima, pedindo os dados específicos que precisa em cada etapa (exatamente como fizemos no Módulo 08 para alertas), e eu respondo como se fosse o ambiente real respondendo às suas consultas.

3. Um exemplo de hipótese (sem walkthrough resolvido)

Para você já começar a pensar, aqui está o **tipo** de hipótese que usaríamos numa sessão real — sem resolver:

"Threat Intelligence recente (Módulo 12) indica que um grupo tem usado DNS Tunneling (T1071.004, Módulo 03 Aula 4) para exfiltrar dados pequenos aos poucos, evitando detecção por volume. Nosso ambiente tem logs de DNS de todos os hosts nos últimos 30 dias, mas nenhuma regra específica para esse padrão ainda existe."

Se essa hipótese fosse sua, tente esboçar mentalmente (sem escrever a resposta, só pensando):

1. Que campo de um log de DNS você olharia primeiro, e por quê?
2. Que padrão de "raridade" ou "unicidade" (Aula 1) faria sentido procurar aqui especificamente?
3. Se você encontrasse um domínio suspeito, qual seria seu próximo pivot?

Quando quiser desenvolver essa mesma hipótese de verdade, ao vivo, é só pedir.

4. Conectando com o resto da formação

Threat Hunting usa:

Módulo 12 (TI) → de onde vêm as hipóteses baseadas em ameaça conhecida
Módulo 13 (ATT&CK) → estrutura para hunting orientado a técnica
Módulo 09 (SIEM) → onde as queries realmente rodam
Módulo 10 (EDR) → telemetria profunda de host, se a hipótese for local
Módulo 08 (SOC) → achados confirmados viram casos/incidentes
Módulo 21 (Detection Engineering, à frente) → lacunas encontradas viram novas regras de detecção

5. Recapitulando o Módulo 14

- O roteiro de hunting: hipótese → escopo → baseline → query inicial → pivot → timeline → conclusão e documentação.
- Um resultado "vazio" ou "não confirmado" ainda tem valor — melhora o baseline ou revela uma lacuna de detecção.

- Hunting não tem gabarito fixo — a prática real acontece interativamente, formulando e testando hipóteses ao vivo.

Módulo 14 concluído. 🎉

Próximo módulo

Módulo 15 — Incident Response: quando um alerta (Módulo 08) ou uma caça (este módulo) confirma um achado real, aqui está o processo completo de resposta — do primeiro minuto até o relatório final.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2:** já citada em módulos anteriores — a fase de detecção e análise se conecta diretamente com o roteiro de hunting apresentado aqui. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **MITRE ATT&CK — "Groups" e "Software":** fontes diretas para gerar hipóteses baseadas em TTPs de grupos reais. <https://attack.mitre.org/groups/>